

Figure 1: Web services and OSI layers

Modern Web applications often do not just deliver content in the form of simple Web pages. Business logic and data warehousing components such as a database server, application servers and middleware software are also used to generate and provide business-specific data to the website users. These components are usually installed and run on a separate set of servers, and may or may not share storage space with each other. Advanced Web application code may internally call Web services hosted on different servers, and the resultant page is delivered to the client. Web programmers also use cookies to maintain sessions and to store session-specific information in the client browser.

Web hacking

It is fairly easy to hack a website. A novice hacker may attempt to steal data from a website, whereas a pro hacker may cause serious damage by either defacing the site, or using the Web server to spread a virus. Unlike most other attacks, the techniques used in Web attacks range from Layer 2 to Layer 7 attacks, thus making the Web server susceptible to a wider variety of possible hacking attempts. Since the firewall port must be opened for the Web service (by default, port 80), it cannot help in preventing Layer 7 attacks, which makes the detection of Web attacks difficult. Please refer to Figure 2, which shows the typical components used to form Web portal infrastructure. From the security perspective, each of these components does exhibit some vulnerability, which if exploited, can result in hacking of Web content. Let us now discuss some common yet dangerous attacks in detail.

DoS and sniffing: Since the website is hosted on an IP address open to the Internet, a denial of service attack can easily take the Web server down. Similarly, packet sniffing can easily be used to capture plain-text user IDs and passwords on the wire, if encryption or other security measures are not put in place during Web designing. Almost all Layer 2 and 3 attacks such as packet flooding, SYN flooding, etc., are possible on a

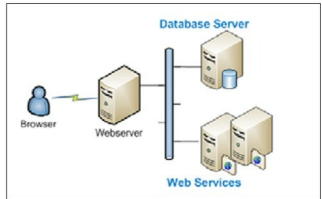


Figure 2: Web portal infrastructure

website IP and the port on which it is hosted.

HTTP DoS attack: Unlike a network-layer-based denial of service attack, an HTTP DoS attack works at Layer 7. In this type of attack, the website is programmatically crawled to get a list of pages to be accessed, during which the attacker also makes note of the time required by the server to process each page. Those pages that require higher processing time are selected, and multiple HTTP requests are sent to the Web server, each requesting one of the selected pages. To cater to each request, the Web server starts consuming resources. Upon reaching its resource limits, it eventually gives up and stops responding. Hackers are known to use simple scripts to create a flood of HTTP GET requests to achieve this attack. If the website contains only simple static HTML pages, this attack does not work very well. However, if dynamic pages pull data from a back-end database server, this attack can wreak considerable damage. While it may or may not result in data theft, it certainly shuts the website down, creating a bad user experience and damage to the reputation. Intelligent techniques must be deployed to detect and stop such attacks, which we will learn about shortly.

Access control exploitation: Usually, in the case of Web portals, a user is given an ID and a password to log in and perform certain functions. Portal administrators are also given their own credentials for maintenance and data management. If the Web services and applications are not designed to be secure from the coding perspective, hackers can exploit those to gain elevated privileges. For example, if a Web server is not patched with the latest security fixes, which may result in remote code execution, hackers can possibly write a *script* to exploit that vulnerability and gain access to the server and control it remotely. In some cases, this can happen because the best coding and security practices are not followed, leaving holes in the security configuration, and making the Web solution susceptible to attacks.